

L'Attaque de l'Homme du Milieu (Man-in-the-Middle - MITM)

1 Définition

L'attaque **Man-in-the-Middle (MITM)** est une forme d'interception de communication où un attaquant s'insère secrètement entre deux parties (généralement appelées Alice et Bob) qui croient communiquer directement l'une avec l'autre.

L'attaquant ne se contente pas d'écouter la conversation (attaque passive); il peut intercepter, modifier ou injecter des messages dans le flux de données (attaque active) sans que les participants ne s'en aperçoivent.

2 Le mécanisme de l'attaque

Dans un scénario de chat vocal chiffré, l'attaque survient généralement lors de l'échange de clés (Key Exchange).

2.1 Schéma conceptuel

Imaginons qu'Alice souhaite établir une connexion sécurisée avec Bob via un protocole de type Diffie-Hellman :

1. Alice envoie sa clé publique A à Bob.
2. L'attaquant (Eve) intercepte A et envoie sa propre clé publique E à Bob.
3. Bob reçoit E , pensant qu'il s'agit de A , et répond avec sa clé publique B .
4. Eve intercepte B et renvoie sa propre clé E à Alice.

À la fin de cet échange :

- Alice a établi une clé partagée avec Eve : $K_{AE} = g^{ae} \pmod{p}$.
- Bob a établi une clé partagée avec Eve : $K_{BE} = g^{be} \pmod{p}$.

Conséquence

Eve déchiffre le flux audio d'Alice avec K_{AE} , peut l'écouter ou le modifier, puis le ré-encrypte avec K_{BE} pour l'envoyer à Bob. La latence induite est le seul indice potentiel de l'attaque.

3 Vecteurs d'attaque courants

En réseau, plusieurs techniques permettent de forcer le passage par l'attaquant :

- **ARP Spoofing** : Sur un réseau local (LAN), associer l'adresse MAC de l'attaquant à l'adresse IP de la passerelle.
- **DNS Spoofing** : Détourner les requêtes de résolution de noms pour diriger le client vers un serveur malveillant.
- **Attaque par déclassement (Downgrade Attack)** : Forcer les clients à utiliser des versions obsolètes et vulnérables de protocoles (ex : forcer du TLS 1.0 au lieu de 1.3).

4 Contre-mesures pour un Chat Vocal

Le chiffrement seul ne protège pas du MITM. Il faut coupler le chiffrement à l'**Authentification**.

4.1 Authentification par tiers de confiance (PKI)

L'utilisation de certificats numériques signés par une Autorité de Certification (CA). Alice et Bob vérifient la chaîne de confiance du certificat reçu avant de finaliser l'échange de clés.

4.2 Fingerprinting (Short Authentication String - SAS)

Dans les applications de chat vocal sécurisé (comme Signal ou ZRTP), on utilise souvent un **SAS**. Il s'agit d'une version courte du hash de la clé

de session. Les deux utilisateurs lisent à voix haute une suite de mots ou de chiffres affichés sur leur écran. S'ils ne correspondent pas, un MITM est présent.

4.3 HSTS et Certificate Pinning

Mesures techniques visant à forcer les connexions sécurisées et à n'accepter que des certificats spécifiques prédéfinis dans l'application.